



America's Cyber Defense Agency

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

FACT SHEET

Information Technology (IT) Sector-Specific Goals (SSGs)

Publish Date: January 07, 2025

RELATED TOPICS: [CYBERSECURITY BEST PRACTICES](#),
[ORGANIZATIONS AND CYBER SAFETY](#)

Information Technology (IT) Sector-Specific Goals (SSGs) Overview

The IT SSGs are additional voluntary practices with high-impact security actions, beyond the Cross-Sector CPGs, that outline measures IT Sector businesses and critical infrastructure owners can take to protect themselves against cyber threats. They were developed based on CISA's operational data, research on the current threat landscape, and in collaboration with government, industry groups, and private sector experts.

Learn more about the Cross-Sector CPGs that SSGs are based off of by clicking here: [Cybersecurity Performance Goals \(CPGs\)](#).

Software Development (SD) Process Goals

IT/SD SSG #1 - Separate all environments used in software development

Outcome:

- All environments used in software development, including development, build, test, and distribution environments, are separated from each other to prevent unauthorized access to sensitive data and systems

TTP or Risk Addressed:

- Reduce the risk of lateral movement or privilege escalation between development and sensitive business environments (TA0008)

Scope:

- All software development environments.

Recommended Action:

- All software development environments should be logically separated from each other and enforced via controls such as network segmentation and access controls.

Measurement

- Do organizations separate all environments used in software development, including development, build, test, and distribution? (Yes/No)

NIST SSDF Reference:

- PO.5.1

NIST CSF 2.0 Reference:

- PR.PS-06
- PR.IR-01
- PR.IR-03

CISA Secure Software Development Attestation

- 1a) Separating and protecting each environment involved in developing and building software;

Cost:

- Medium

Impact:

- High

Complexity:

- High

IT/SD SSG #2 - Regularly log, monitor, and review trust relationships used for authorization and access across software development environments

Outcome:

- All software development environments and tooling have associated logging and monitoring mechanisms

TTP or Risk Addressed:

- Lateral movement, privilege escalation, insider threats, data exfiltration

Scope:

- All software development environments.

Recommended Action:

- Perform a review of all software development environments and tooling to verify associated logging capabilities and functions are enabled.

Measurement

- Do organizations have the ability to audit access all environments used in software development? (Yes/No)
- Are audit logs available and monitored? (Yes/No)

NIST SSDF Reference:

- PO.5.1

NIST CSF 2.0 Reference:

- PR.PS-04
- DE.CM-03
- DE.CM-06
- DE.CM-09

CISA Secure Software Development Attestation

- 1b) Regularly logging, monitoring, and auditing trust relationships used for authorization and access:
 - i) to any software development and build environments; and
 - ii) among components within each environment;

Cost:

- Medium

Impact:

- High

Complexity:

- Medium

IT/SD SSG #3 Enforce Multi-Factor Authentication (MFA) across software development environments**Outcome:**

- Users are required to authenticate into software development environments with multi-factor authentication (MFA)

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement, code misconfigurations, outdated code dependencies

Scope:

- Software.

Recommended Action:

- Require MFA (ideally phishing-resistant MFA) to access all software development environments.

Measurement

- Is MFA required to access all software development environments? (Yes/No)

NIST SSDF Reference:

- PO.5.1
- PO.5.2

NIST CSF 2.0 Reference:

- PR.AA-01
- PR.AA-03
- PR.AA-04
- PR.AA-05

CISA Secure Software Development Attestation

- 1c) Enforcing multi-factor authentication and conditional access across the environments relevant to developing and building software in a manner that minimizes security risk;

Cost:

- Low

Impact:

- High

Complexity:

- Low

IT/SD SSG #4 Establish and enforce security requirements for software products used across software development environments

Outcome:

- Organizations have defined processes, policies, and procedures for managing risks of software products used across software development environments

TTP or Risk Addressed:

- Misconfigurations, Shadow IT, supply chain vulnerabilities, insecure code

Scope:

- Software.

Recommended Action:

- Document processes, policies, and procedures for managing risks of software products used across software development environments.
- Maintain, replace, and remove software in accordance with policies, processes, and procedures.
- Assess the authenticity and integrity of software prior to use in environments.

Measurement

- Do organizations have documentation that defines policies, processes, and procedures for managing risks of software products used across development environments? (Yes/No)
- Has the authenticity and integrity of the software been verified prior to installation in development environments? (Yes/No)

NIST SSDF Reference:

- PO.5.1

NIST CSF 2.0 Reference:

- ID.AM-08
- ID.RA-09
- PR.PS-02

- PR.PS-05

CISA Secure Software Development Attestation

- 1d) Taking consistent and reasonable steps to document and minimize use or inclusion of software products that create undue risk in the environments used to develop and build software;

Cost:

- Low

Impact:

- High

Complexity:

- Medium

IT/SD SSG #5 Securely store and transmit credentials used in software development environments

Outcome:

- Organizations have eliminated the insecure storage and transmission of plaintext credentials

TTP or Risk Addressed:

- Lateral movement, privilege escalation, insider threats, data exfiltration

Scope:

- All software development environments.

Recommended Action:

- Do not store sensitive data or credentials in source code. Instead, store sensitive data and credentials in an encrypted manner, such as using a secret manager.
- Securely store and rotate SSH keys.

Measurement

- Have organizations eliminated the insecure storage of credentials and other sensitive data in source code? (Yes/No)

NIST SSDF Reference:

- PO.5.2

NIST CSF 2.0 Reference:

- ID.AM-08
- PR.DS-01
- PR.DS-02
- PR.DS-10

CISA Secure Software Development Attestation

- 1e) Encrypting sensitive data, such as credentials, to the extent practicable and based on risk;

Cost:

- Medium

Impact:

- High

Complexity:

- Medium

IT/SD SSG #6 Implement effective perimeter and internal network monitoring solutions with streamlined, real-time alerting to aid responses to suspected and confirmed cyber incidents**Outcome:**

- The organization monitors environments to determine the presence of indicators of compromise (IOCs).

- Upon determination of suspected or actual IOCs, the incident response playbook is activated.

TTP or Risk Addressed:

- Initial access, lateral movement, command and control (C2), privilege escalation, data exfiltration, insider threats

Scope:

- Hardware, software, and firmware.

Recommended Action:

- Establish an incident response playbook with criteria for declaring incidents, along with protocols that clearly define roles, responsibilities, and identifies stakeholders who require notification.
- Designate an enterprise incident response team and conduct frequent tabletop exercises.

Measurement

- Do organizations have perimeter and internal network monitoring solutions with real time alerting capabilities? (Yes/No)
- Do organizations have a documented incident response playbook with defined criteria and protocols to follow once an incident is declared? (Yes/No)

NIST SSDF Reference:

- PO.3.2
- PO.3.3
- PO.5.1
- PO.5.2

NIST CSF 2.0 Reference:

- DE.CM-01
- DE.CM-03
- DE.CM-06
- DE.CM-09

CISA Secure Software Development Attestation

- 1f) Implementing defensive cybersecurity practices, including continuous monitoring of operations and alerts and, as necessary, responding to suspected and confirmed cyber incidents;

Cost:

- High

Impact:

- High

Complexity:

- Medium

IT/SD SSG #7 Establish a software supply chain risk management program

Outcome:

- Cybersecurity supply chain risk management practices are integrated into the software development lifecycle.

TTP or Risk Addressed:

- Code tampering, outdated code dependencies, data breaches.

Scope:

- Software.

Recommended Action:

- Conduct code testing and audit software supply chain practices and document the activities conducted.

Measurement

- Do organizations have documentation that explicitly defines the roles, responsibilities, and requirements for code testing? (Yes/No)

- Do organizations document code testing and auditing activities involving software supply chain practices? (Yes/No)

NIST SSDF Reference:

- PO 1.1
- PO.3.1
- PO.3.2
- PO.5.1
- PO.5.2
- PS.1.1
- PS.2.1
- PS.3.1
- PW.4.1
- PW.4.4
- PW 7.1
- PW 8.1
- RV 1.1

NIST CSF 2.0 Reference:

- ID.AM-02
- GV.SC-01
- GV.SC-02
- GV.SC-03
- GV.SC-04
- GV.SC-05
- GV.SC-06
- GV.SC-07
- GV.SC-08
- GV.SC-09
- GV.SC-10

CISA Secure Software Development Attestation

- 2) The software producer is making a dedicated effort to maintain trusted source code supply chains for both internally produced and third party-provided components;

Cost:

- High

Impact:

- High

Complexity:

- Medium

IT/SD SSG #8 Make a Software Bill of Materials (SBOM) available to customers

Outcome:

- Customers should be provided with documentation that demonstrates component provenance.

TTP or Risk Addressed:

- Code tampering, outdated code dependencies, data breaches.

Scope:

- Software.

Recommended Action:

- Develop a Software Bill of Materials (SBOM) and provide it to customers with each product.

Measurement

- Do organizations have a Software Bill of Materials (SBOM) that accompanies their software products? (Yes/No)

NIST SSDF Reference:

- PO.1.3

- PO.3.2
- PO.5.1
- PO.5.2
- PS.3.1
- PS.3.2
- PW.4.1
- PW.4.4
- RV.1.1
- RV.1.2

NIST CSF 2.0 Reference:

- GV.SC-03
- GV.SC-06
- GV.SC-07

CISA Secure Software Development Attestation

- 3) The software producer maintains provenance for internal code and third-party components incorporated into the software to the greatest extent feasible;

Cost:

- High

Impact:

- High

Complexity:

- High

IT/SD SSG #9 Inspect source code for vulnerabilities through automated tools or comparable processes and mitigate known vulnerabilities prior to any release of products, versions, or update releases

Outcome:

- Security testing is conducted in a codified, repeatable, and time sensitive fashion on new and current products.

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement, code misconfigurations, outdated code dependencies.

Scope:

- Software.

Recommended Action:

- Perform Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), and Software Composition Analysis (SCA) where appropriate.

Measurement

- Do organizations employ automated tools or comparable processes that inspect source code for vulnerabilities prior to product, version, or update releases? (Yes/No)

NIST SSDF Reference:

- PO.4.1
- PO.4.2
- PS.1.1
- PW.2.1
- PW.4.4
- PW.5.1
- PW.6.1
- PW.6.2
- PW.7.1
- PW.7.2
- PW.8.2
- PW.9.1
- PW.9.2
- RV.1.1

- RV.1.2
- RV.1.3
- RV.2.1
- RV.2.2
- RV.3.3

NIST CSF 2.0 Reference:

- ID.AM-02
- ID.AM-08
- ID.RA-09
- PR.PS-02
- PR.PS-06

CISA Secure Software Development Attestation

- 4a) The software producer employs automated tools or comparable processes that check for security vulnerabilities. The software producer operates these processes on an ongoing basis and, at a minimum, prior to product, version, or update releases;

Cost:

- Medium

Impact:

- High

Complexity:

- Medium

IT/SD SSG #10 Address identified vulnerabilities prior to product release

Outcome:

- Identification of vulnerabilities prior to release triggers an action to either remediate or address the vulnerability before release.

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement, code misconfigurations, outdated code dependencies.

Scope:

- Software.

Recommended Action:

- Develop, maintain, and execute a process or policy that governs actions to take upon identification of a security vulnerability prior to a product release.

Measurement

- Is there a codified policy or process whereby any vulnerabilities identified before release are addressed? (Yes/No)

NIST SSDF Reference:

- PO.4.1
- PO.4.2
- PS.1.1
- PW.2.1
- PW.4.4
- PW.5.1
- PW.6.1
- PW.6.2
- PW.7.1
- PW.7.2
- PW.8.2
- PW.9.1
- PW.9.2
- RV.1.1
- RV.1.2
- RV.1.3

- RV.2.1
- RV.2.2
- RV.3.3

NIST CSF 2.0 Reference:

- ID.AM-08
- ID.RA-01
- ID.RA-04
- ID.RA-05

CISA Secure Software Development Attestation

- 4b) The software producer has a policy or process to address discovered security vulnerabilities prior to product release;

Cost:

- Low

Impact:

- High

Complexity:

- Medium

IT/SD SSG #11 Publish a vulnerability disclosure policy**Outcome:**

- Publish a vulnerability disclosure policy that meets the defined criteria.

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement, code misconfigurations, outdated code dependencies.

Scope:

- Software.

Recommended Action:

- Publish a vulnerability disclosure policy (VDP) that authorizes testing by members of the public on products offered by the manufacturer, commits to not recommending or pursuing legal action against anyone engaging in good faith efforts to follow the VDP, provides a clear channel to report vulnerabilities, and allows for public disclosure of vulnerabilities in line with coordinated vulnerability disclosure best practices and international standards.
- Address disclosed software vulnerabilities in a timely fashion.

Measurement

- Do organizations have a published vulnerability disclosure policy that meets the defined criteria? (Yes/No)

NIST SSDF Reference:

- PO.4.1
- PO.4.2
- PS.1.1
- PW.2.1
- PW.4.4
- PW.5.1
- PW.6.1
- PW.6.2
- PW.7.1
- PW.7.2
- PW.8.2
- PW.9.1
- PW.9.2
- RV.1.1
- RV.1.2
- RV.1.3
- RV.2.1
- RV.2.2

- RV.3.3

NIST CSF 2.0 Reference:

- ID.RA-01
- ID.RA-04
- ID.RA-05
- ID.RA-08

CISA Secure Software Development Attestation

- 4c) The software producer operates a vulnerability disclosure program and accepts, reviews, and addresses disclosed software vulnerabilities in a timely fashion and adheres to any timelines specified in the vulnerability disclosure program or applicable policies.

Cost:

- Low

Impact:

- High

Complexity:

- Low

Product Design (PD) Goals

IT/PD SSG #1 Increase the use of multifactor authentication (MFA)

Outcome:

- More users use MFA to authenticate

TTP or Risk Addressed:

- TA0006 Credential Access.

- Reduce the risk of password compromise or utilization of weak passwords.

Scope:

- Software.

Recommended Action:

- Increase the use of MFA, such as by implementing enabling MFA (ideally, phishing-resistant MFA) by default for users and administrators.
- Implementing “seat belt chimes” in products to nudge users towards enabling MFA. This could include, banners or interstitials notifying users or administrators that MFA is not enabled or suggesting that administrators enable phishing-resistant MFA.
- Supporting standards-based single sign-on (SSO) in the baseline version of the product, allowing customers to configure with their own identity provider that supports MFA.

Measurement

- What percent of users on the organization's products use MFA?

NIST SSDF Reference:

- PO.1.1
- PO.1.2
- PO 1.3

NIST CSF 2.0 Reference:

- PR.AA-02
- PR.AA-03
- PR.AA-04

Cost:

- Low

Impact:

- High

Complexity:

- Low

IT/PD SSG #2 Reduce default passwords

Outcome:

- The product does not use default passwords

TTP or Risk Addressed:

- T0812 Default Credentials.
- Adversaries may leverage manufacturer or supplier set default credentials on control system devices.

Scope:

- Software.

Recommended Action:

Eliminate default passwords from the organization's software products. Instead, take an alternate approach, such as:

- Providing random, instance-unique initial passwords for the product.
- Requiring the user who installs the product to create a strong password at the start of the installation process.
- Providing time-limited setup passwords that disable themselves when a setup process is complete and require configuration of a secure password (or more secure authentication approaches, such as phishing-resistant MFA).
- Requiring physical access for initial setup and the specification of instance-unique credentials.
- Conducting campaigns or offering updates that transition existing deployments from default passwords to more secure authentication mechanisms..

Measurement

- How many of the organization's products use default passwords?

NIST SSDF Reference:

- PO.1.1
- PO.1.2
- PO 1.3

NIST CSF 2.0 Reference:

- PR.AA-01;

Cost:

- Low

Impact:

- High

Complexity:

- Medium

IT/PD SSG #3 Reduce entire classes of vulnerabilities

Outcome:

- Organizations should proactively reduce systemic classes of vulnerabilities

TTP or Risk Addressed:

- Code tampering, outdated code dependencies, data breaches

Scope:

- Software.

Recommended Action:

Take approaches to work towards reduce entire classes of vulnerabilities, such as:

- Implement parameterized queries to reduce SQL injection vulnerabilities.
- Transition to utilizing memory safe languages to reduce memory safety vulnerabilities.
- Utilize web template frameworks to reduce cross-site scripting (XSS) vulnerabilities.

Measurement

- Has the organization taken steps toward reducing classes of vulnerabilities from their products? (Yes/No)

NIST SSDF Reference:

- PO.1.2
- RV.3.3

NIST CSF 2.0 Reference:

- PR.PS-02
- PR.PS-06;

Cost:

- High

Impact:

- High

Complexity:

- High

IT/PD SSG #4 Provide customers with security patching in a timely manner

Outcome:

- Security patches are offered on a widespread basis to customers

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement

Scope:

- Software.

Recommended Action:

- Provide security patches to customers in a timely manner and on a widespread basis

Measurement

- Do organizations provide security patches to customers in a timely manner and on a widespread basis? (Yes/No)

NIST SSDF Reference:

- RV.2.2

NIST CSF 2.0 Reference:

- PR.DS-01
- PR.PS-02

Cost:

- Medium

Impact:

- High

Complexity:

- Medium

IT/PD SSG #5 Ensure customers understand when products are nearing end of life support and security patches will no longer be provided

Outcome:

- Users understand when software is no longer supported and will transition to supported products

TTP or Risk Addressed:

- Inadequate patching of software vulnerabilities exposes systems to significant risk

Scope:

- Software.

Recommended Action:

- Notify customers and confirm receipt of notification stating product(s) are nearing end of life support and security patches will no longer be provided.

Measurement

- Do organizations notify customers and confirm receipt of notification stating product(s) are nearing end of life support and security patches will no longer be provided to customers? (Yes/No)

NIST SSDF Reference:

- PO.1.2

NIST CSF 2.0 Reference:

- ID.AM-08
- PR.PS-06

Cost:

- Low

Impact:

- High

Complexity:

- Low

IT/PD SSG #6 Include Common Weakness Enumeration (CWE) and Common Platform Enumeration (CPE) fields in every Common Vulnerabilities and Exposures (CVE) record for the organization's products.

Outcome:

- CVEs that meet the defined criteria are published and CWE and CPE fields are included in all CVEs.

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement, code misconfigurations, outdated code dependencies.

Scope:

- Software.

Recommended Action:

- Include accurate Common Weakness Enumeration (CWE) and Common Platform Enumeration (CPE) fields in every Common Vulnerabilities and Exposures (CVE) record for the organization's products. Additionally, issue CVEs in a timely manner for, at minimum, all critical or high impact vulnerabilities (whether discovered internally or by a third party) that either require actions by a customer to patch or have evidence of active exploitation.

Measurement

- Do the organization's CVEs include the CPE and CWE fields? (Yes/No)
- Does the organization publicly describe their policy for when a CVE is issued? (Yes/No)

NIST SSDF Reference:

- PO.4.1
- PO.4.2
- PS.1.1
- PW.2.1
- PW.4.4
- PW.5.1
- PW.6.1
- PW.6.2
- PW.7.1
- PW.7.2
- PW.8.2
- PW.9.1

- PW.9.2
- RV.1.1
- RV.1.2
- RV.1.3
- RV.2.1
- RV.2.2
- RV.3.3

NIST CSF 2.0 Reference:

- ID.RA-08

Cost:

- Low

Impact:

- High

Complexity:

- Medium

IT/PD SSG #7 Increase the ability for customers to gather evidence of cybersecurity intrusions affecting the organization's products**Outcome:**

- Customers have access and ability to monitor and respond to intrusions affecting the product.

TTP or Risk Addressed:

- Initial access, privilege escalation, lateral movement.

Scope:

- Software.

Recommended Action:

- Verify whether all products, to the extent possible, have logging capabilities.

Measurement

- Do all customers have the ability to monitor and respond to cybersecurity intrusions affecting the organization's products? (Yes/No)

NIST SSDF Reference:

- PO.5.1

NIST CSF 2.0 Reference:

- PR.PS-04
- DE.CM-09

Cost:

- Low

Impact:

- High

Complexity:

- Low